Information Security, Access Control & Cloud Infrastructure Policy

Enterprise Compliance Directive • Ref: POL-SEC-003

ORGANIZATIONAL POLICY MANUAL	**Policy Code:** POL-SEC-003
Document: Information Security, Access Control & Cloud Infrastructure Policy	**Version:** 5.0 | **Effective:** 2025-01-01
Category: Information Security	**Business Area:** IT, DevOps & Engineering
Compliance Owner: Chief Information Security Officer (CISO)	**Classification:** Confidential - Internal Corporate Use

1. Policy Purpose & Executive Scope

Mandates strict technical and organizational measures including Zero Trust architecture, privileged access management, multi-factor authentication, cloud security guardrails, and audit logging.

2. Binding Regulatory Clauses & Compliance Requirements

Section 1.1: Principle of Least Privilege and Role-Based Access Control [POL-SEC-003-C01]

Requirement: MANDATORY | Risk Impact: HIGH | Regulatory Base: ISO/IEC 27001:2022 Control A.5.15, A.8.2; SOC 2 CC6.1, CC6.3

Access to corporate information systems, source code repositories, databases, and customer environments must be granted strictly on the Principle of Least Privilege and implemented via Role-Based Access Control (RBAC). Standing administrator rights on employee endpoints or production infrastructure are strictly prohibited.

Section 2.2: Universal Multi-Factor Authentication (MFA) Requirement [POL-SEC-003-C02]

Requirement: MANDATORY | Risk Impact: CRITICAL | Regulatory Base: NIST SP 800-63B AAL2/AAL3; CISA Zero Trust Guidance

Phishing-resistant Multi-Factor Authentication (MFA)—utilizing FIDO2/WebAuthn hardware security keys or managed authenticator applications—is universally mandatory for all employee accounts, VPN connections, cloud management consoles (AWS, Azure, GCP), and sensitive SaaS services. SMS-based OTP is prohibited for privileged administrators.

Section 3.3: Production Environment Access & Just-In-Time (JIT) Elevation [POL-SEC-003-C03]

Requirement: MANDATORY | Risk Impact: CRITICAL | Regulatory Base: SOC 2 Type II CC6.6; ISO 27001 A.8.18

Direct SSH, RDP, or root console access to live production environments is prohibited. Emergency access must be obtained through a Privileged Access Management (PAM) bastion using Just-In-Time (JIT) access requests requiring dual-person engineering manager approval, automatic session screen recording, and automated credential expiration within a maximum of 4 hours.

Section 4.2: Audit Logging, SIEM Integration & 365-Day Retention [POL-SEC-003-C04]

Requirement: MANDATORY | Risk Impact: HIGH | Regulatory Base: PCI-DSS v4.0 Req 10; SOC 2 CC7.2; NIST SP 800-92

All authentication attempts, privilege elevations, database queries against customer tables, firewall modifications, and administrative actions must be forwarded in real time to the centralized SIEM platform. Audit logs must be cryptographically signed, stored in immutable write-once-read-many (WORM) storage, and retained for not less than 365 calendar days.

Section 5.4: Critical Vulnerability Remediation SLA [POL-SEC-003-C05]

Requirement: MANDATORY | Risk Impact: HIGH | Regulatory Base: FedRAMP Incident & Vulnerability Standards; CISA BOD 22-01

Any vulnerability identified in production systems or public-facing applications with a Common Vulnerability Scoring System (CVSS v3) score of 9.0 or higher must be remediated or mitigated within 72 hours of discovery. High-severity vulnerabilities (CVSS 7.0-8.9) must be patched within 14 calendar days.